

ASTRAL Supplementary Material

This document provides supplementary information for our work on ASTRAL. It includes detailed derivations, additional experimental results, implementation details, and extended analyses that complement the main paper.

1 Probabilistic Analysis Formulations

This section summarises the probabilistic analysis formulations used in ASTRAL, adapted from Huang et al. [2].

1.1 Probabilities of Exposure

For vulnerability nodes, a distinction is made between those with public disclosure via Common Vulnerabilities and Exposures (CVE) identifiers and those that are proprietary or undocumented, lacking formal CVE enumeration. Vulnerabilities with CVE identifiers are assessed using the Common Vulnerability Scoring System (CVSS), while those without CVEs are assigned proxy-CVSS estimates based on observed characteristics. Exposure probabilities are derived by quantifying the exploitability factors defined in the CVSS specification [1], as detailed in the following formula:

$$P(Exposure)_{\text{vuln}} = AV \times AC \times PR \times UI \quad (1)$$

In addition, we introduce an attack feasibility (AF) modifier, inspired by Xie et al. [6], to further refine vulnerability exposure probability estimations and account for real-world conditions. The AF modifier adjusts the probability based on system security posture, adversary capabilities, and environmental constraints. Systems with up-to-date defences and restricted access are associated with lower AF values, reflecting reduced likelihood of successful attack. In contrast, an unpatched CPS exposed to a skilled adversary will exhibit higher AF values and consequently higher probabilities of successful attack. The final probability of successful attack for a vulnerability node is therefore given by:

$$P(Attack)_{\text{vuln}} = P(Exposure)_{\text{vuln}} \times \phi \quad (2)$$

where $P(Attack)_{\text{vuln}}$ represents the probability of successful attack, $P(Exposure)_{\text{vuln}}$ is the vulnerability exposure probability, and ϕ is the attack feasibility modifier.

For *asset nodes*, the probability of exposure equates to probability of failure, modelled by exponential decay [3]:

$$P(Exposure)_{\text{asset}} = 1 - e^{-\lambda t} \quad (3)$$

where λ denotes the failure rate per unit time, and t denotes the asset's operational duration.

Hazard nodes represent hazardous events, failures, or disruptions influenced by attack propagation. As such, the occurrence of a hazard is influenced by the cyber-physical dependencies within the system. If the parent node of a hazard is an asset or hazard, then the failure of the parent node increases the likelihood of hazard activation and propagates risk, potentially escalating the attack scenario. The probability of hazard exposure is thus represented as:

$$P(Exposure)_{\text{hazard}} = \begin{cases} 1, & \text{if parent fails or occurs} \\ 0, & \text{otherwise} \end{cases} \quad (4)$$

1.2 Probabilities of Severe Impact

For *vulnerability nodes*, the probability of severe impact is computed as:

$$P(Impact)_{\text{vuln}} = 1 - [(1 - C) \cdot (1 - I) \cdot (1 - A)] \quad (5)$$

where: $P(Impact)_{\text{vuln}}$ denotes the probability of severe impact, and C, I, A represent the CVSS impact metrics for confidentiality, integrity, and availability, respectively. For proprietary or undocumented vulnerabilities, these metrics are estimated using system context or analogous vulnerabilities.

For *asset* and *hazard nodes*, the structural impact score reflects the number of child nodes each individual node directly influences, capturing its potential to propagate disruption or failure through the system:

$$S(a) = \frac{\text{No. of connected child nodes}}{\text{Total no. of nodes in the BN graph}} \quad (6)$$

1.3 Computing Risk and Availability Scores

Once exposure and impact probabilities for vulnerability, asset, and hazard nodes are determined, the posterior probabilities of exposure (or attack success in the case of vulnerability nodes) and severe impact are calculated using conditional probability formulations and VE techniques. The composite risk score, representing the joint likelihood of successful exposure and severe impact, is computed as the product of these posterior probabilities:

$$Risk = P(Exposure)_{\text{posterior}} \times P(Impact)_{\text{posterior}} \quad (7)$$

In parallel, system availability can be derived as an inverse measure reflecting the probability that neither exposure nor severe impact occurs. This probabilistic complement captures the expected operational continuity of the system under uncertainty and is expressed as:

$$Availability = (1 - P(Exposure)_{\text{posterior}}) \times (1 - P(Impact)_{\text{posterior}}) \times 100 \quad (8)$$

In this work's context, the availability value (expressed as a percentage) quantifies the confidence that the system remains unaffected by both exploit attempts and consequential disruptions, complementing the risk score within the same probabilistic assessment framework.

1.4 Construction of Conditional Probability Tables

The conditional probability tables (CPTs) for BN nodes with parents are computed by multiplying parent node states with node-specific base probabilities from Equations (1)–(6). For example, consider vulnerability node V with parent asset node A . The CPT is constructed as:

$$P(V = 1|A = 0) = 0.05, \quad P(V = 1|A = 1) = P(Exposure)_{\text{vuln}} = 0.47$$

Resulting CPT:

A	$V = 0$	$V = 1$
0	0.95	0.05
1	0.53	0.47

2 Validation Against SWaT Reference Architecture

The architectural artefacts used for validation of ASTRAL's reconstruction correctness against the Secure Water Treatment (SWaT) Testbed reference architecture [4], are reproduced here for reference.

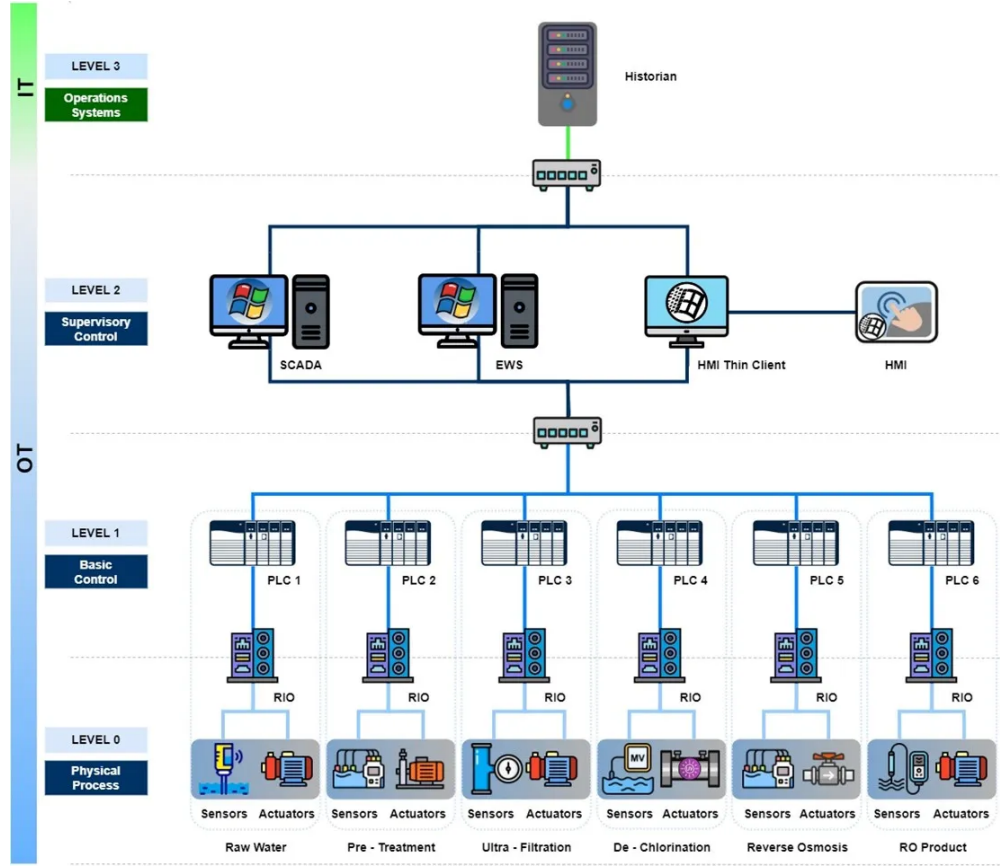


Figure 1: Reference network architecture for Secure Water Treatment (SWaT) testbed [4]

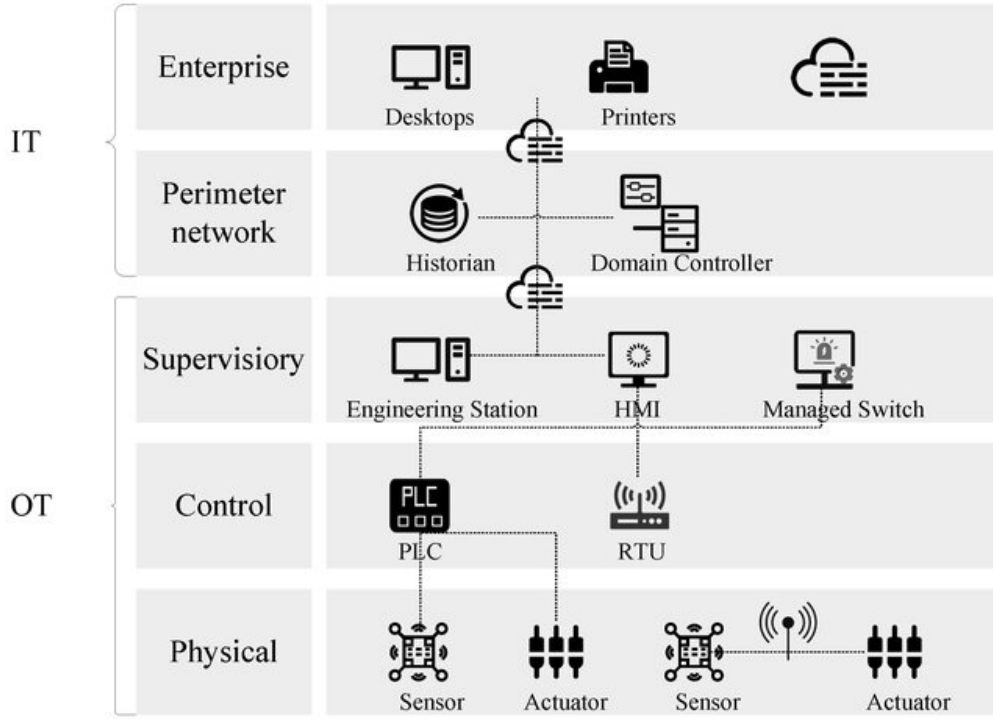


Figure 2: Open-source visual artefact depicting the SWaT testbed [5]

The SWaT Network Architecture, i.e., the cyber portion of SWaT, comprises dedicated OT hardware in Allen-Bradley Programmable Logic Controllers (PLCs), Schneider Remote Input/Output (RIO) units and a combination of IT software and hardware in the Human Machine Interfaces (HMIs), Supervisory Control and Data Acquisition (SCADA) workstation and Historian.

The SCADA supervises the SWaT process through periodical monitoring and has the ability to take manual control of the SWaT testbed by overriding the pre-existing PLC programming. The SCADA also works in conjunction with the Historian which serves the important role of recording and storing process data for subsequent analysis. The IT and OT components co-exist on a network that employs a layered communications network using the Purdue Model for Industrial Control Systems (ICS). The PLCs use the EtherNet/IP (ENIP) as the main communication protocol.

Notable aspects of the testbed include segmented communications networks, both wired and wireless communications, distributed dynamic control, interconnection among the testbeds, and complete access to the control logic within the PLCs and HMIs. The SWaT testbed employs the use of Wireless Access Points (WAP) to achieve wireless communications. This accessibility allows researchers to develop and upload their code in the controllers for research and experimentation. It also provides a platform for demonstrating their technologies in a safe, controlled, and realistic environment.

Figure 3: Textual artefact for Secure Water Treatment (SWaT) testbed [4]

2.1 Structural Fidelity Evaluation

We conducted a direct structural comparison of the reconstructed narrations against the SWaT reference architecture. Rather than measuring fidelity through downstream BN outputs, this evaluation scores each narration (Figures 4, 5, 6) at the level of discrete architectural items, enabling independent assessment of recall, precision, and F1.

Attacker or Attack-Capable Entities: External network adversary (implied); internal operator/researcher with privileged access to PLCs and HMIs; maintenance personnel with physical access to control hardware; SCADA system repurposable as an attack vector via manual override capability. Key Components: Allen-Bradley Programmable Logic Controllers (PLCs); Schneider Remote Input/Output (RIO) units; Human Machine Interfaces (HMIs); SCADA workstation; Historian (time-series database); Wireless Access Points (WAPs); layered communications network (Purdue Model); EtherNet/IP (ENIP) backbone; testbed interconnection links; distributed dynamic control architecture. Trust Boundaries and Purdue Zones: Level 0 (physical process, implied); Level 1 basic control (PLCs, RIOs); Level 2 supervisory control (SCADA, HMIs); Level 3 site operations (Historian); IT/OT convergence boundary (shared network segments); wireless/wired boundary (WAPs); research access boundary (full read/write privilege to PLC and HMI control logic); physical security boundary (implied). Data Flows & Interactions: PLC↔PLC peer coordination via ENIP; PLC↔RIO I/O data exchange; PLC↔HMI/SCADA telemetry and control commands; SCADA↔Historian process data logging; HMI↔operator interaction; WAP-mediated wireless communication links; programming data (control logic upload/download to PLCs and HMIs); testbed-to-testbed interconnection flows. Technologies and Protocols: EtherNet/IP (ENIP) as primary OT protocol; wired Ethernet backbone; IEEE 802.11 wireless (WAPs); Allen-Bradley/Rockwell platform; Schneider Electric RIO platform; Purdue Model/IEC/ISA-95 framework; IEC 62443 (implied); SCADA/HMI and Historian platforms (unspecified). Assets and Functions: PLCs (real-time water treatment control); RIOs (distributed I/O aggregation); HMIs (operator monitoring and control); SCADA (supervisory override); Historian (process logging and forensic analysis); WAPs (wireless connectivity); testbed interconnection infrastructure. Attack Entry Points: WAP wireless interface (rogue association, MITM); ENIP protocol exploitation (replay, command injection); SCADA/HMI exposed services; Historian database (tampering, exfiltration); testbed interconnection as pivot point; PLC/HMI programming ports (physical and research access); operator workstation (social engineering); SCADA manual override misuse; firmware/logic upload via research pathway; wireless jamming.
--

Figure 4: Architectural narration reconstructed from the SWaT reference architecture

2.1.1 Experimental Design

We extracted six analytical dimensions from the reconstructed narrations based on the published SWaT reference architecture (Figure 1) and the visual / textual artefacts: (1) attacker and attack-capable entities, (2) key system components, (3) trust boundaries and Purdue zones, (4) data flows and interactions, (5) technologies and protocols, and (6) attack entry points. Within each dimension and narration, we enumerated discrete reference items, yielding a total of 62 items distributed as shown in Table 1.

Two architectural narrations were evaluated: one reconstructed from a visual artefact (an open-source network diagram of SWaT (Figure 2)) and one from a textual artefact extracted from the SWaT testbed website (Figure 3), both produced using ASTRAL with Mistral Medium 3.5 under the full configuration (multimodal input, guardrails enabled, temperature = 0.1, top- p = 0.9).

Each item in the respective reconstructed narrations was scored against the reference narration as follows: a score of 1 was assigned for a confirmed match (correct vendor, component type, protocol, or trust boundary); a score of 0.5 for a partial or generic match (correct category but missing specificity, e.g., “PLC” without vendor identification); and a score of 0 for items absent

Attacker or Attack-Capable Entities: External adversaries exploiting network-facing interfaces; internal operators or maintenance personnel misusing credentials; supply chain entities with access to firmware updates or remote support tools; compromised field devices vulnerable to lateral movement; malicious insiders within IT networks with access to IT/OT convergence points.

Key Components: PLCs/RTUs managing physical processes; field devices (sensors, actuators, I/O modules); SCADA/HMI systems; Historians; engineering workstations for PLC programming and configuration; OT networks (industrial Ethernet, serial segments); DMZ components (firewalls, proxies); enterprise IT integration (MES/ERP, remote access gateways); patch management servers; authentication servers.

Trust Boundaries and Purdue Zones: Level 0 (physical process); Level 1 basic control (PLCs/RTUs, I/O modules); Level 2 supervisory control (SCADA/HMI, Historians); Level 3 site operations (engineering workstations, local servers); Level 3.5 DMZ (firewalls, protocol breakers, unidirectional gateways); Level 4 enterprise (MES, ERP, cloud systems); implied air gaps between critical control segments; microsegmentation via VLANs or physical separation.

Data Flows & Interactions: Real-time sensor readings from PLCs to SCADA/Historians via Modbus TCP or OPC UA; operator-initiated control commands from HMI to PLCs; alarm notifications from OT to IT; PLC logic updates from engineering workstations via FTP or S7 protocol; analog/digital signals (4–20 mA, HART, Modbus RTU) from field devices to I/O modules; control signals to actuators; vendor/operator remote sessions via VPN or RDP; cloud synchronisation via MQTT or REST APIs.

Technologies and Protocols: Modbus TCP/RTU, PROFINET, EtherNet/IP, DNP3 (OT real-time control); PROFIsafe or CIP Safety (SIS, if present); ISA100.11a or WirelessHART (wireless field devices); OPC UA, MQTT, REST/gRPC (IT/OT data exchange); RDP, SSH, vendor remote support tools; firewalls, deep packet inspection; RADIUS/TACACS+ authentication; TLS encryption; Siemens S7, Rockwell ControlLogix, Schneider Quantum (PLC platforms); Aveva, Siemens PCS 7, Ignition (SCADA); OSIsoft PI, GE Proficy, InfluxDB (Historians).

Assets and Functions: PLCs/RTUs (process control); safety controllers (emergency shutdown); sensors (turbidity, chlorine, flow); actuators (valves, pumps); network infrastructure (industrial switches, routers, WAPs); process control loops; safety instrumentation; data acquisition; remote operation; maintenance interfaces.

Attack Entry Points: Internet-exposed VPN gateways or web-based HMIs; misconfigured DMZ services; rogue access points or weak WPA2-PSK; HMI/SCADA USB ports (social engineering); engineering workstations (infected project files); local PLC serial/Ethernet ports; field device tampering (spoofing 4–20 mA signals); malicious firmware via vendor update servers or USB drives; vulnerable OPC UA clients or MES connectors with hardcoded credentials; unencrypted Modbus TCP/DNP3 sessions (MITM, replay); legacy RS-485 networks (command injection); exploitable OPC UA servers or database links bridging IT/OT; weak or default credentials on OT devices.

Figure 5: Architectural narration reconstructed from the visual artefact

Attacker or Attack-Capable Entities: External adversaries exploiting wireless communications (WAPs) or network segmentation flaws; insider threats (operators/researchers) with privileged access to upload or modify PLC and HMI control logic; automated systems (SCADA manual override) repurposable by an attacker to inject rogue commands.

Key Components: Allen-Bradley PLCs (core control logic, programmable via code uploads); Schneider Remote I/O (RIO) units (distributed I/O for field device connectivity); HMIs (operator monitoring and control, co-located with OT on shared network segments); SCADA workstation (supervisory layer with manual override capability); Historian (time-series process data storage); Wireless Access Points (WAPs); layered communications network (Purdue Model, Levels 0–4 implied); EtherNet/IP (ENIP) backbone (PLC-to-PLC, PLC-to-HMI/SCADA, PLC-to-RIO); testbed interconnection links (shared or bridged networks); distributed dynamic control (decentralised PLC coordination).

Trust Boundaries and Purdue Zones: Level 0 (field devices/sensors/actuators via RIOs, implied); Level 1 basic control (PLCs, RIOs, ENIP-dominant); Level 2 supervisory control (SCADA, HMIs, manual override bridges IT/OT); Level 3 site operations (Historian, likely co-located with SCADA); Level 4 enterprise (implied upstream); IT/OT convergence boundary (SCADA/HMI/Historian share segments with PLCs/RIOs); wireless/wired boundary (WAPs); research access boundary (privileged code-upload pathway bypassing standard operational controls); testbed interconnection boundary (bridged networks extending trust externally).

Data Flows & Interactions: PLC↔PLC peer coordination via ENIP; PLC↔RIO I/O exchange (sensor readings, actuator commands); PLC↔HMI/SCADA telemetry and control (SCADA polls PLCs, issues overrides); SCADA↔Historian process data logging (periodic or event-triggered); HMI↔operator interaction (monitoring/control, social engineering vector); WAP-mediated wireless links (HMI-to-PLC, mobile devices to SCADA); programming data (control logic upload/download to/from PLCs and HMIs); control commands (SCADA-to-PLC overrides, PLC-to-actuator signals); telemetry (sensor data: flow, pressure, chemical levels); historical data (process logs stored in Historian).

Technologies and Protocols: EtherNet/IP (ENIP) as dominant OT protocol (CIP-based, real-time); wired Ethernet backbone; IEEE 802.11 wireless (WAPs, assumed); Purdue Model (IEC/ISA-95) as structural framework; IEC 62443 (implied); Allen-Bradley/Rockwell Automation PLC platform; Schneider Electric RIO platform; SCADA/HMI platform (unspecified, e.g. Wonderware, Ignition); Historian platform (unspecified, e.g. OSIsoft PI, AVEVA).

Assets and Functions: PLCs (water treatment control loops: filtration, chlorination); RIOs (field I/O aggregation, single point of failure for sensor/actuator data integrity); actuators/sensors (valves, pumps, level sensors, implied); real-time control (chemical dosing, flow regulation); supervisory override (SCADA manual override, high-risk if compromised); data logging (Historian: forensic analysis, process optimisation); wireless connectivity (WAPs: remote monitoring/control); control logic access (full read/write to PLC/HMI code for research); testbed interconnection (cross-testbed attack or exfiltration surface).

Attack Entry Points: WAP wireless interface (rogue associations, MITM, weak encryption); ENIP protocol (eavesdropping, replay, unauthorised command injection via CIP exploits); SCADA/HMI interfaces (OPC UA, Modbus TCP if present: lateral movement, privilege escalation); Historian database (data tampering, log falsification, exfiltration); testbed interconnection links (pivot points for cross-testbed attacks); PLC/HMI programming ports (direct code injection via physical access or researcher accounts); operator workstations (phishing to gain HMI/SCADA credentials); maintenance interfaces (unsecured serial/Ethernet ports on PLCs/RIOs); SCADA manual override function (rogue control commands); firmware/logic uploads via research access pathways; wireless jamming (WAP disruption inducing process instability).

Figure 6: Architectural narration reconstructed from the textual artefact

Table 1: Reference item counts per analytical dimension

Dimension	Reference items
Attacker entities	6
Key components	12
Trust boundaries	9
Data flows & interactions	11
Technologies & protocols	13
Attack entry points	11
Total	62

from the narration or contradicted by the reference, including hallucinations. Formally, let M_R denote the sum of match scores over all reference items for a given narration, let N_{ref} denote the total reference item count, and let N_{nar} denote the total item count of the narration. Then:

$$\text{Recall} = \frac{M_R}{N_{\text{ref}}}, \quad \text{Precision} = \frac{M_R}{N_{\text{nar}}}, \quad \text{F1} = \frac{2 \cdot \text{Recall} \cdot \text{Precision}}{\text{Recall} + \text{Precision}} \quad (9)$$

2.1.2 Results

Table 2: Full enumeration of discrete reference items across six analytical dimensions, scored for the visual (V) and textual (T) narrations against the SWaT reference architectural narration. (Scores: **1** = confirmed match; **0.5** = partial or generic match; **0** = absent or hallucinated.)

#	Dimension	Reference item			V	T	Notes
Attacker entities (6 items)							
1	Attacker entities	External network adversary			0.5	0.5	Both present but generic; reference implies internet-facing threat
2	Attacker entities	Internal operator / researcher with privileged access			0.5	1	Textual correctly identifies researcher code-upload risk; visual generic
3	Attacker entities	Maintenance personnel			0.5	0.5	Both partially cover; reference distinguishes maintenance as separate actor
4	Attacker entities	Supply chain / vendor entity			0*	0	Visual adds supply chain actor; absent from reference — hallucination
5	Attacker entities	Physical intruder			0	0	Absent from both narrations; present in reference
6	Attacker entities	SCADA repurposing as attack vector			0	1	Textual uniquely identifies SCADA manual override misuse; visual misses
Key components (12 items)							
7	Key components	Allen-Bradley (vendor-specific)	PLCs		0*	1	Visual substitutes Siemens S7 — hallucination; textual correct
8	Key components	Schneider (RIO) units	Remote I/O		0	1	Textual names Schneider RIO specifically; visual omits

Continued on next page.

Table 2 continued.

#	Dimension	Reference item	V	T	Notes
9	Key components	HMIs (Human Machine Interfaces)	1	1	Both correctly identified
10	Key components	SCADA workstation	1	1	Both correctly identified
11	Key components	Historian (time-series database)	1	1	Both correctly identified
12	Key components	Wireless Access Points (WAPs)	0.5	1	Textual names WAPs specifically; visual generic wireless reference
13	Key components	Layered communications network (Purdue Model)	0.5	1	Textual explicit; visual partially covered
14	Key components	EtherNet/IP (ENIP) backbone	0*	1	Visual substitutes PROFINET — hallucination; textual correct
15	Key components	Testbed interconnection links	0	1	Unique SWaT feature; absent from visual, correctly in textual
16	Key components	Distributed dynamic control architecture	0.5	1	Textual explicit; visual generic distributed control reference
17	Key components	Engineering workstations	0*	0	Visual adds; absent from reference — hallucination
18	Key components	Patch management / authentication servers	0*	0	Visual adds enterprise IT layer; absent from reference — hallucination
Trust boundaries (9 items)					
19	Trust boundaries	Purdue Level 0 — physical process	1	0.5	Visual more explicit; textual implied only
20	Trust boundaries	Purdue Level 1 — basic control (PLCs/RIOs)	1	1	Both correctly identified
21	Trust boundaries	Purdue Level 2 — supervisory control (SCADA/HMI)	1	1	Both correctly identified

Continued on next page.

Table 2 continued.

#	Dimension	Reference item	V	T	Notes
22	Trust boundaries	Purdue Level 3 — site operations (Historian)	0.5	1	Textual explicit; visual places Historian at enterprise level
23	Trust boundaries	IT/OT convergence boundary	0.5	1	Textual correctly flags shared network segments; visual generic
24	Trust boundaries	Wireless / wired boundary (WAPs)	0.5	1	Textual explicit; visual partially covered
25	Trust boundaries	Research access boundary (code-upload privilege)	0	1	Unique to SWaT testbed; absent from visual, correctly in textual
26	Trust boundaries	Physical security boundary	0	0	Absent from both; present in reference
27	Trust boundaries	Level 3.5 DMZ / microsegmentation	0*	0	Visual adds DMZ layer; absent from reference — hallucination
Data flows & interactions (11 items)					
28	Data flows	PLC ↔ PLC peer coordination (ENIP)	0	1	Visual substitutes PROFINET; textual correctly names ENIP
29	Data flows	PLC ↔ RIO I/O data exchange	0.5	1	Textual explicit; visual generic field-level flow
30	Data flows	PLC ↔ HMI/SCADA telemetry and control	1	1	Both correctly identified
31	Data flows	SCADA ↔ Historian process data logging	1	1	Both correctly identified
32	Data flows	HMI ↔ operator interaction	0.5	1	Textual explicit; visual generic operator interface
33	Data flows	WAP wireless communication links	0	1	Textual explicit; visual omits WAP-specific flow

Continued on next page.

Table 2 continued.

#	Dimension	Reference item	V	T	Notes
34	Data flows	Programming data — logic upload/download to PLCs	0	1	Unique SWaT research feature; correctly in textual, absent from visual
35	Data flows	Testbed-to-testbed interconnection flow	0	0.5	Textual partial; visual absent
36	Data flows	Vendor remote support sessions (RDP/VPN)	0*	0	Visual adds; absent from reference — hallucination
37	Data flows	Cloud sync / MES/ERP integration flows	0*	0	Visual adds enterprise IT flows; absent from reference — hallucination
38	Data flows	Analog field signals (4–20 mA / HART)	0*	0	Visual adds field-level signals; absent from reference – hallucination
Technologies & protocols (13 items)					
39	Technologies	EtherNet/IP (ENIP) — primary OT protocol	0	1	Visual substitutes PROFINET; textual correct
40	Technologies	Wired Ethernet backbone	0.5	1	Textual explicit; visual generic Ethernet reference
41	Technologies	IEEE 802.11 wireless (WAPs)	0.5	0.5	Both partially covered; neither names standard explicitly
42	Technologies	Allen-Bradley / Rockwell platform	0	1	Visual substitutes Siemens/generic; textual correct
43	Technologies	Schneider Electric RIO platform	0	1	Textual names Schneider; visual omits
44	Technologies	Purdue Model / IEC/ISA-95 framework	1	1	Both correctly identified
45	Technologies	IEC 62443 (implied)	0.5	0.5	Both reference as implied; neither confirms explicit implementation

Continued on next page.

Table 2 continued.

#	Dimension	Reference item	V	T	Notes
46	Technologies	PROFINET / DNP3 / BAC-net	0*	0	Visual asserts; absent from reference — hallucination
47	Technologies	ISA100.11a / WirelessHART	0*	0	Visual asserts wireless OT protocols; absent from reference — hallucination
48	Technologies	OPC UA / MQTT / REST APIs	0*	0	Visual adds IT/OT integration layer; absent from reference — hallucination
49	Technologies	IPsec VPN / remote access protocols	0*	0	Visual adds; absent from reference — hallucination
50	Technologies	SCADA/HMI software platform (unspecified)	0.5	0.5	Both note platform unspecified; consistent with reference
51	Technologies	Historian platform (unspecified)	0.5	0.5	Both note platform unspecified; consistent with reference
Attack entry points (11 items)					
52	Attack entry points	WAP wireless interface (rogue association / MITM)	1	1	Both correctly identified
53	Attack entry points	ENIP protocol exploitation	0	1	Textual names ENIP; visual substitutes generic Modbus/DNP3
54	Attack entry points	SCADA/HMI exposed services	1	1	Both correctly identified
55	Attack entry points	Historian database (tampering / exfiltration)	0.5	1	Textual explicit; visual generic database reference
56	Attack entry points	Testbed interconnection as pivot point	0	0.5	Textual partial; visual absent
57	Attack entry points	PLC/HMI programming ports (physical / research access)	0.5	1	Textual names research pathway specifically; visual generic
58	Attack entry points	Operator workstation social engineering	1	1	Both correctly identified

Continued on next page.

Table 2 continued.

#	Dimension	Reference item	V	T	Notes
59	Attack entry points	SCADA manual override misuse	0	1	Textual uniquely identifies; visual absent
60	Attack entry points	Firmware / logic upload via research pathway	0	1	Textual uniquely identifies; visual absent
61	Attack entry points	Wireless jamming	0	1	Textual identifies; visual absent
62	Attack entry points	Supply chain firmware / counterfeit devices	0*	0	Visual adds; not evidenced in reference — hallucination
Aggregate (62 ref. items)			0.34	0.70	Macro-averaged recall across all dimensions

Table 3: Summary of recall, precision, and F1 scores for visual and textual narrations against the SWaT reference architectural narration. Partial matches scored at 0.5. Bold indicates the higher F1 per dimension.

Dimension	Visual narration			Textual narration		
	R	P	F1	R	P	F1
Attacker entities	0.25	0.50	0.33	0.50	0.75	0.60
Key components	0.38	0.75	0.50	0.83	1.00	0.91
Trust boundaries	0.50	0.75	0.60	0.72	0.93	0.81
Data flows & interactions	0.27	0.75	0.40	0.68	0.94	0.79
Technologies & protocols	0.27	0.58	0.37	0.54	0.78	0.64
Attack entry points	0.36	0.80	0.50	0.86	0.95	0.90
Aggregate	0.34	0.70	0.46	0.70	0.91	0.79

The textual narration achieves an aggregate F1 of 0.79 (recall 0.70, precision 0.91), outperforming the visual narration (F1 0.46, recall 0.34, precision 0.70) by 33 percentage points. Textual recall exceeds visual recall across all six dimensions, with the most pronounced gaps occurring in the attack entry points dimension (textual: 0.90 vs. visual: 0.50), data flows and interactions dimension (0.79 vs. 0.40), and the key components dimension (0.91 vs. 0.50).

Sources of visual narration gaps. The visual narration’s lower precision (0.70 vs. 0.91) and recall highlight a systematic vulnerability to hallucination and omission when parsing graphical inputs. When the diagram lacks explicit textual labels, the model tends to substitute generic ICS knowledge for SWaT-specific detail. In the key components dimension, the visual narration

misidentifies vendor components, substituting Siemens S7 PLCs for the actual Allen-Bradley controllers present in SWaT, while entirely omitting critical testbed interconnection links. Within the technologies dimension, it introduces protocols not present in the reference architecture, such as PROFINET, DNP3, BACnet, ISA100.11a, and WirelessHART, alongside OPC UA, MQTT, and REST APIs for an enterprise integration layer. For data flows, the model reconstructed enterprise-IT patterns like cloud synchronisation, vendor RDP sessions, and MES/ERP integration that do not exist in the reference architecture.

Textual narration strengths. Conversely, the textual narration successfully anchors its architectural reconstruction to SWaT-specific evidence. It correctly identifies Allen-Bradley PLCs and Schneider Remote I/O units by vendor, specifies EtherNet/IP (ENIP) as the dominant OT protocol, captures the testbed interconnection links as an architectural component, and identifies both the SCADA manual override function and the researcher code-upload pathway as distinct trust boundaries — the latter being a feature unique to the testbed context that generic ICS reasoning would not produce.

The structural recall and precision metrics reported here provide the complementary evidence needed to evaluate whether a reconstructed architecture is a credible basis for downstream security decisions.

3 Ablation Study

This section presents the ablation study using three case studies: *FrostyGoop* (incomplete DFD), *Medical CPS (MCPS)* (high-level schematic), and *Solar PV Inverter* (BN graph). Four variants systematically disable or modify key design elements relative to a *Full ASTRAL* baseline (multimodal input with guardrails enabled, temperature = 0.1, top- p = 0.9):

- *Text-Only* (no diagrams, guardrails on)
- *No-Guardrails* (full multimodal, guardrails off)
- *High temperature* (multimodal + guardrails, temperature = 0.9)
- *Low top- p* (multimodal + guardrails, top- p = 0.1)

Each variant was run ten times per case study using identical prompts and the same LLM (Mistral 3.1 Medium). The artefacts for the Text-Only experiments, the prompts for the No-Guardrails experiments, and the evaluation metrics and corresponding statistical analysis are described in the subsequent sections.

3.1 Artefacts for Text-Only Experiments

The artefacts used for the Text-Only experiments are as follows:

The image shows the connectivity of a utility management and automated heating system. The components are arranged in a top-down hierarchy, starting from the internet and moving down to local meters and substation modules.

System Connectivity and Flow

- The MicroTik Router sits at the top of the hierarchy, connected to the Internet. It has two primary downward connections: one via Ethernet to the ENCO Reader/Workstation and another via Ethernet/USB to the ENCO Controller.
- The ENCO Reader/Workstation acts as a central hub, maintaining a bi-directional Ethernet/USB link with the ENCO Controller and a USB connection to the ENCO Terminal.
- The ENCO Controller manages several data streams. It connects to the ENCO Box using RF (Radio Frequency) and to the Gas/Electric Meter using the MBus protocol.
- The ENCO Box serves as a collection point for multiple meters. It receives data from the Gas/Electric Meter via MBus and from the Water Meter via RF. It then sends data to the Heat Meter via an Ethernet connection.
- At the bottom of the diagram, the Automated Heating Substation Module receives signals from the ENCO Terminal via RF. This module then directs data or control signals via Ethernet to both the Water Meter and the Heat Allocator. Finally, the Heat Allocator is linked to the Heat Meter through an Ethernet connection.

Key Protocols Identified

- Ethernet/USB: Used for high-level communication between the router, workstation, and controller.
- RF (Radio Frequency): Used for wireless communication between the terminal, substation, and meters.
- MBus: A specialized bus protocol used specifically for the Gas and Electric meters to communicate with the controller and box.

Figure 7: Text-Only artefact for FrostyGoop

This diagram illustrates a Medical Cyber-Physical System (MCPS) network, showing the interconnectedness between a central medical association, hospital facilities, mobile units, and patient-specific medical devices.

- **Network Core (The Medical Association):** At the center of the architecture is the Medical Association, which acts as a hub for multiple hospital facilities. These facilities are interconnected via Network transmission equipment (represented by routers) and wireless lightning-bolt icons, indicating a high-level wide-area network.
- **Hospital Facilities and Diagnostic Equipment:** Each hospital node is connected to various heavy diagnostic and specialized systems:
 - Hyperbaric oxygen storage equipment
 - Chest X-ray equipment
 - Nuclear magnetic resonance (MRI) equipment
 - Ultrasonic diagnosis instrument
- **Mobile and Remote Communication:** The system extends beyond the physical walls of the hospital through several communication channels:
 - Remote communication: Linked to the hospital nodes to facilitate off-site data exchange.
 - Ambulance and Mobile communication: Ambulances are shown connected to the hospital network via wireless links, ensuring real-time data flow during patient transport.
- **Patient-Centric Devices and Wearables:** The bottom and left side of the diagram detail the "Cyber-Physical" aspect, focusing on devices directly interacting with the patient:
 - Implantable Devices: This includes a Brain chip and a Heart pacemaker.
 - Wearables: A Medical Bracelet is used for continuous monitoring.
- **Mobility and Rehabilitation:** The network includes a Smart Wheelchair, Leg rehabilitation equipment, and a Smart hospital bed, all of which are integrated into the hospital's data environment.

Summary of System Flow

The architecture demonstrates a nested hierarchy where:

- Personal/Physical devices feed data into local hospital systems.
- Local systems coordinate with specialized diagnostic equipment and mobile units.
- Hospital nodes synchronize at the top level under the Medical Association umbrella to ensure a unified health record and response system.

Figure 8: Text-Only artefact for MCPS

=This diagram illustrates a threat model for a Solar PV Inverter system, mapping out vulnerabilities (labeled V), hazards or impacts (labeled H), and the flow of potential cyberattacks from user-facing applications down to the physical power grid.

System Entry Points and Application Layer The top of the diagram identifies the primary interfaces for user interaction:

- Mobile/Web Application: Connects to several vulnerabilities including decrypting communications (V1), man-in-the-middle server impersonation (V2), and hardcoded MQTT credentials (V3).
- WiNet Web UI: Directly linked to a vulnerability involving hardcoded passwords (V4).

Central Communication and Cloud Services The core of the digital infrastructure involves the SunGrow iSolarCloud (MQTT Broker). This component is susceptible to multiple vulnerabilities:

- IDOR (Insecure Direct Object Reference) Vulnerabilities: A series of five distinct IDOR flaws (V6 through V10), each associated with a specific CVE from 2024, can be exploited through the cloud broker.
- Impersonation: The MQTT broker can be impersonated (V5) following an exploit of hardcoded passwords.
- Communication Hardware and Firmware Vulnerabilities: Data flows from the cloud and management layers to the WiNet-S Communication Dongle. This hardware is vulnerable to several Denial of Service (DoS) or Remote Code Execution (RCE) attacks:
 - Buffer Overflows: Three stack-based buffer overflows (V11, V12, V13) and one heap-based buffer overflow (V14).
 - Firmware Injection: An attacker can inject controlled firmware (V15) to gain control over the device.

Cyber-Physical Impact and Grid Hazards The bottom of the diagram shows how digital exploits translate into physical consequences for the Solar PV Inverter and the Power Grid:

- Immediate Hazards: Potential impacts include data leakage (H1), hijacking other devices (H2), and cyber-physical ransomware (H3).
- Operational Interference: Exploits can lead to altered energy production (H4) or a dynamic load attack (V16).
- Grid Consequences: These operational failures can result in load shedding (H5), emergency equipment failure (H6), and grid instability (H7).
- Ultimate Outcome: The final catastrophic impact at the bottom of the chain is a Power Outage (H8).

Figure 9: Text-Only artefact for solar PV inverter

3.2 LLM Prompts for No-Guardrails Experiments

The LLM prompts used for the No-Guardrails experiments are as follows:

You are a Senior Solution Architect tasked with narrating a system architectural diagram (e.g., Data Flow Diagram) to a Senior Security Architect experienced in IEC 62443 and the Purdue model. Think deeply to thoroughly analyse the diagram and provide a structured architectural narration strictly based on visible content.

Figure 10: No-Guardrails architectural reconstruction prompt

You are a senior cyber security expert with over 20 years of experience in cyber-physical systems (CPS) risk and threat modelling, including deep expertise in STRIDE-LM and safety/security co-analysis. You have applied STRIDE-LM extensively in ICS, SCADA, and related CPS domains. Your task is to think deeply to thoroughly analyse the provided system architectural diagram (e.g., Data Flow Diagram) along with any accompanying documentation to produce a comprehensive list of specific threat scenarios relevant to the application.

Figure 11: No-Guardrails threat modelling prompt

3.3 Evaluation Metrics

Reconstruction quality is evaluated across objective, no-ground-truth metrics capturing architectural reconstruction accuracy:

- **Valid Trust Boundaries:** The count of identified security perimeters that respect documented communication protocols and logical isolation (e.g., wireless sensor to gateway transitions, rather than direct EHR to wearable interconnections).
- **Semantic Coherence:** An *LLM-as-a-judge* [7] metric quantifying the logical consistency and technical clarity of the reconstructed architecture. The scoring prompt directs an independent LLM to act as an impartial judge: *“Please act as an impartial judge and evaluate how semantically coherent is this architecture description for CPS security analysis? Be as objective as possible. Please rate on a Likert scale of 1-5.”*

3.4 Metric Acquisition

Metrics were acquired through a two-stage process combining expert visual inspection against reference architectures with automated LLM-based verification.

Semantic Coherence. Evaluated via the *LLM-as-a-judge* framework, this metric assesses the logical consistency and technical actionability of the architecture’s markdown output. The prompt directs an independent model to rate the description on a 1–5 Likert scale, quantifying how effectively the narrative supports downstream security analysis. An example of the judge’s scoring output is provided in Figure 12.

Coherence Rating: 4.9/5.0

Outstanding comprehensive ICS CPS architecture description demonstrating precise Purdue L4→L3.5→L3→L2→L1→L0 zone alignment with DMZ specification, detailed bidirectional IT/OT data flows across fieldbus→OPC UA→REST protocols, comprehensive wireless/safety protocol coverage, and systematic threat modelling matching established IEC 62443 methodology standards.

Figure 12: Semantic coherence evaluation output

Valid Trust Boundaries. Boundaries identified within the reconstructed architecture were validated visually against Purdue reference models and case study documentation. This was further confirmed via a targeted LLM prompt: *“Review this architectural narrative and count the number of valid trust boundaries.”*

An example of the LLM’s output is shown in Figure 13.

conn=0.95, impos=4

Parsed 100+ nodes from ICS CPS attack graph spanning G02-G08 STRIDE goals with Purdue level mappings.

Identified violations: direct wireless sensor→SCADA sans L1 PLC mediation; flat IT/OT network lacking DMZ boundary; maintenance workstation→PLC bypassing L2 supervisory controls; unsegmented historian→field device access path.

Figure 13: Connectivity & impossible path evaluation results

3.5 Statistical Analysis

Statistical significance was assessed using the Wilcoxon signed-rank test comparing each variant against the baseline across the three runs ($n = 3$). Ties (identical scores) contribute zero rank; positive ranks (variant $>$ baseline) sum to W_+ , negative ranks (variant $<$ baseline) to W_- , total non-zero ranks $W = W_+ + W_-$. The test statistic is $\min(W_+, W_-)$; p-values were computed via exact permutation for small n .

For example, Trust BD scores baseline: 7,7,6; Text-Only: 5,5,5 yield paired differences, absolute ranks all negative, so $W_+ = 0$, $W_- = 6$, $W = 6$, $p=0.051$ (one-sided).

The exploratory threshold $p=0.10$ reflects the family-wise error rate under independent tests, treated as suggestive rather than confirmatory due to small n and multiple testing. Bold p-values in tables indicate suggestive degradation.

3.6 Experimental Results

This subsection presents the ablation results for the three case studies, comparing the Full ASTRAL baseline against the four variants across all metrics and statistical tests.

Table 4: Ablation Experimental Results: FrostyGoop

Setting		Run 1	Run 2	Run 3	Average	SD	W+	W-	W	p-value
Baseline	Trust BD Coh.	7	4	4	5.10	1.29	–	–	–	–
		4.8	4.9	4.9	4.85	0.05	–	–	–	–
Text-Only	Trust BD Coh.	4	5	3	3.90	0.88	31	5	5	0.0325
		4.4	4.6	4.3	4.58	0.14	55	0	0	0.0023
No-Guardrails	Trust BD Coh.	3	5	6	4.00	1.05	34.5	10.5	10.5	0.0754
		4.9	4.8	4.9	4.89	0.03	3.5	17.5	3.5	0.0512
High Temp	Trust BD Coh.	8	8	8	7.50	1.08	0	55	0	0.0024
		4.7	4.6	4.7	4.64	0.18	48	7	7	0.0181
Low top- p	Trust BD Coh.	7	9	6	6.70	1.42	1.5	26.5	1.5	0.0165
		4.7	4.9	4.9	4.75	0.16	25	3	3	0.0303

Legend: **Trust BD** = valid trust boundaries; **Coh.** = semantic coherence. Only the first 3 experimental runs are shown for brevity; Average and SD are calculated across all 10 runs. W_+ , W_- , and W denote Wilcoxon signed-rank test statistics. p -values are reported only for pairs that differ from their baseline values; a **bold** p -value indicates a result below our pre-specified exploratory threshold of 0.10, which we treat as suggestive rather than confirmatory evidence.

Table 5: Ablation Experimental Results: Medical CPS (MCPS)

Setting		Run 1	Run 2	Run 3	Average	SD	W+	W-	W	p-value
Baseline	Trust BD Coh.	6	4	6	4.80	1.32	–	–	–	–
		4.8	4.9	4.9	4.84	0.07	–	–	–	–
Text-Only	Trust BD Coh.	3	3	5	4.10	1.29	31.5	13.5	13.5	0.1400
		4.4	4.6	4.7	4.69	0.14	28	0	0	0.0085
No-Guardrails	Trust BD Coh.	7	6	5	4.30	1.42	24	12	12	0.1942
		4.8	4.8	4.7	4.89	0.10	11.5	24.5	11.5	0.1781
High Temp	Trust BD Coh.	7	8	8	7.90	1.60	0	45	0	0.0038
		4.9	4.8	4.8	4.82	0.04	11.5	24.5	11.5	0.1781
Low top- p	Trust BD Coh.	10	7	6	8.60	1.65	0	45	0	0.0036
		4.9	4.9	4.7	4.83	0.08	14.5	13.5	13.5	0.4656

Legend: **Trust BD** = valid trust boundaries; **Coh.** = semantic coherence. Only the first 3 experimental runs are shown for brevity; Average and SD are calculated across all 10 runs. W_+ , W_- , and W denote Wilcoxon signed-rank test statistics. p -values are reported only for pairs that differ from their baseline values; a **bold** p -value indicates a result below our pre-specified exploratory threshold of 0.10, which we treat as suggestive rather than confirmatory evidence.

Table 6: Ablation Experimental Results: Solar PV Inverter

Setting		Run 1	Run 2	Run 3	Average	SD	W+	W-	W	p-value
Baseline	Trust BD	8	8	7	6.50	1.65	–	–	–	–
	Coh.	4.8	4.7	4.5	4.73	0.13	–	–	–	–
Text-Only	Trust BD	5	5	4	3.70	0.95	45	0	0	0.0036
	Coh.	4.7	4.7	4.3	4.58	0.18	42.5	2.5	2.5	0.0083
No-Guardrails	Trust BD	2	6	3	4.70	1.49	38.5	6.5	6.5	0.0284
	Coh.	4.9	4.8	4.9	4.81	0.07	11.5	33.5	11.5	0.0939
High Temp	Trust BD	9	7	7	6.70	1.77	20	25	20	0.3814
	Coh.	4.8	4.7	4.8	4.74	0.13	11.5	16.5	11.5	0.3357
Low top- p	Trust BD	4	5	4	5.40	1.43	38	17	17	0.1399
	Coh.	4.9	4.6	2.3	4.00	0.97	45.5	9.5	9.5	0.0328

Legend: **Trust BD** = valid trust boundaries; **Coh.** = semantic coherence. Only the first 3 experimental runs are shown for brevity; Average and SD are calculated across all 10 runs. W_+ , W_- , and W denote Wilcoxon signed-rank test statistics. p -values are reported only for pairs that differ from their baseline values; a **bold** p -value indicates a result below our pre-specified exploratory threshold of 0.10, which we treat as suggestive rather than confirmatory evidence.

Table 7: Summary: Ablation Study Results Across Three Case Studies (Mean $\pm$ SD, $n = 10$)

Case Study	Variant	Trust BD	Coherence
FrostyGoop	Full ASTRAL	5.10 $\pm$ 1.29	4.85 $\pm$ 0.05
	Text-Only	3.90* $\pm$ 0.88	4.58* $\pm$ 0.14
	No-Guardrails	4.00* $\pm$ 1.05	4.89* $\pm$ 0.03
	High Temp	7.50* $\pm$ 1.08	4.64* $\pm$ 0.18
	Low top- p	6.70* $\pm$ 1.42	4.75* $\pm$ 0.16
Medical CPS	Full ASTRAL	4.80 $\pm$ 1.32	4.84 $\pm$ 0.07
	Text-Only	4.10 $\pm$ 1.29	4.69* $\pm$ 0.14
	No-Guardrails	4.30 $\pm$ 1.42	4.89 $\pm$ 0.10
	High Temp	7.90* $\pm$ 1.60	4.82 $\pm$ 0.04
	Low top- p	8.60* $\pm$ 1.65	4.83 $\pm$ 0.08
Solar PV Inverter	Full ASTRAL	6.50 $\pm$ 1.65	4.73 $\pm$ 0.13
	Text-Only	3.70* $\pm$ 0.95	4.58* $\pm$ 0.18
	No-Guardrails	4.70* $\pm$ 1.49	4.81* $\pm$ 0.07
	High Temp	6.70 $\pm$ 1.77	4.74 $\pm$ 0.13
	Low top- p	5.40 $\pm$ 1.43	4.00* $\pm$ 0.97

Legend: **Trust BD** = valid trust boundaries; **Coherence** = semantic coherence (scored 1–5). Results are reported as Mean $\pm$ SD across $n = 10$ experimental runs. The * denotes statistical significance at our exploratory threshold ($p \leq 0.10$) using the Wilcoxon signed-rank test against the Full ASTRAL baseline.

References

- [1] FIRST. Common Vulnerability Scoring System v3.1: Specification Document. <https://www.first.org/cvss/v3-1/specification-document>, 2015. Accessed: 2026-02-24.
- [2] HUANG, S., POSKITT, C. M., AND SHAR, L. K. Bayesian and Multi-Objective Decision Support for Incident Mitigation in Cyber-Physical Systems. *IEEE Access* *14* (2026), 148923–148942.
- [3] KUMAR, A., SAINI, M., SAINI, D. K., AND BADIWAL, N. Cyber physical systems-reliability modelling: critical perspective and its impact. *International Journal of System Assurance Engineering and Management* *12* (2021), 1334–1347.
- [4] SINGAPORE UNIVERSITY OF TECHNOLOGY AND DESIGN. Secure Water Treatment (SWaT) Testbed. <https://www.sutd.edu.sg/itrust/swat/>, 2026. Accessed: 2026-05-26.
- [5] SONG, Y., HUANG, H., WANG, H., AND WEI, Q. Leveraging Swarm Intelligence for Invariant Rule Generation and Anomaly Detection in Industrial Control Systems. *Applied Sciences* *14*, 22 (2024), 10705.
- [6] XIE, P., LI, J. H., OU, X., LIU, P., AND LEVY, R. Using Bayesian Networks for Cyber Security Analysis. In *2010 IEEE/IFIP international conference on dependable systems & networks (DSN)* (2010), IEEE, pp. 211–220.
- [7] ZHENG, L., CHIANG, W.-L., SHENG, Y., ZHUANG, S., WU, Z., ZHUANG, Y., LIN, Z., LI, Z., LI, D., JORDAN, M., AND STOICA, I. Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena. *arXiv preprint arXiv:2306.05685* (2023).